

Development of Enterprise Security Framework in SKK Migas Based on Integration of ISO 27000 and SABSA Model

Warsun Najib, Sujoko Sumaryono, Lukito Edi Nugroho, Guntur Dharma Putra

Department of Electrical Engineering and Information Technology

Universitas Gadjah Mada

Yogyakarta, Indonesia

warsun@ugm.ac.id, sujoko@ugm.ac.id, lukito@ugm.ac.id, gdputra@ugm.ac.id

Abstract—This paper presents the development of Enterprise Security Framework (ESF) for an Indonesian government institution called SKK Migas (Special Task Force for Upstream Oil and Gas Business Activities). The framework developed based on two security standard namely ISO 27000 and SABSA. The development is started by evaluating available information security standard and best practice used in enterprise scale. The next step is analyzing existing security policy and implementation regarding the Information Security Management System (ISMS) in SKK Migas and then perform gap analysis. The main step is the synthesis of security framework which intended to improve information security management in SKK Migas. The resulted security framework covers 14 security domains which will be used to control information security management within the institution.

Keywords—enterprise security framework; skk migas; iso 27000; SABSA.

I. INTRODUCTION

The advancement of Information Technology (IT) has been playing an important role in organizations and taking part in almost every aspect of the organization. Proper IT implementation may result in beneficial consequences, but some potential threats for data and information security may also rise both from internal and external sources. Some examples of potential threats are web-based information systems which are open for anyone, incomplete security standards, absence of security management and regulation, incompetent network administrator, and even working culture which does not put security in the first place.

As one of the major organizations in Indonesia, especially in oil and gas sector, SKK Migas (Special Task Force for Upstream Oil and Gas Business Activities) of Republic Indonesia is responsible for monitoring oil and gas exploration in order to give maximum prosperity to Indonesian citizens [1]. SKK Migas is established by the Government of the Republic of Indonesia under Presidential Regulation Number 9 of 2013 on Management of Upstream Oil and Gas Business Activities. To achieve its responsibility and function, SKK Migas requires a fine support of IT infrastructures. The IT utilization via strategic and integrated information systems implementation also increases the performance, efficiency, and transparency of monitoring and control of upstream oil and gas activities, which

significantly helps management board of SKK Migas to arrive at right decision [2].

Several threats also emerge in the IT implementation at SKK Migas environment [2]. To prevent such malicious threats, an organization requires an IT security framework that will be implemented entirely in the enterprise level. Several security frameworks have been proposed to tackle this issue, for instance, Open Security Architecture (OSA), Sherwood Applied Business Security Architecture (SABSA), Control Objectives for Information and Related Technology (COBIT), and ISO 27000 family. Initially, SKK Migas implements ISO 27000 standard as the data and information security governance. However, to increase the robustness of the framework, an extension of ISO 27000 standard is needed.

In this paper, we present the development of an Enterprise Security Framework (ESF) based on the integration of two security framework model to increase the robustness of the framework. The result will be implemented specifically for SKK Migas environment.

The rest of this paper is organized as follows. Section II presents the available information security standards and frameworks. Section III describes the method used to develop the ESF. The result of the framework development is presented in Section IV. Lastly, Section V concludes this paper.

II. INFORMATION SECURITY STANDARDS AND FRAMEWORKS

In this section, we review several available standards and frameworks from reputable organizations. We also describe the considerations in choosing the suitable frameworks for a particular organization.

A. Enterprise Architecture Frameworks

1) Federal Enterprise Architecture Framework (FEAF)

FEAF was developed to connect inter-states communication in United States. This framework was initially initiated by CIO boards of United States in 1996 and it came into existence in 1999 as FEAF version 1.1 [3].

2) Department of Defense Architecture Framework Version 2.0 (DoDAF)

DoDAF version 2.0 is a framework with comprehensive conceptual model for US Department of Defense [4]. DoDAF

is designed to make US Department of Defense easier to develop an architecture that enables managers in each managerial level to take more effective decisions by referring to any available information between departments. This framework provides an additional guideline to develop architectures that support its implementation, which is net-centric.

3) The Open Group Architecture Framework (TOGAF)

TOGAF is a popular framework in IT-based enterprise architecture development. TOGAF version 9.1 itself was firstly launched in 2011 [5]. The main objective of TOGAF is to become an approach that is able to develop an enterprise architecture, especially an IT-based enterprise architecture. Unlike FEAF and DoDAF, this framework owns considerably high scalability level. This means that this framework may be implemented in any organization, such as government and even large or small scale enterprise.

B. Security Architecture Frameworks

1) Federal Enterprise Architecture Security and Privacy Profile (FEA-SPP)

FEA is an enterprise architecture framework for analysis, management, and usage of IT inter-organizations in the United States [6]. FEA scheme consists of five linked reference model, such as Performance Reference Model (PRM), Business Reference Model (BRM), Service Component Reference Model (SRM), Technical Reference Model (TRM), Data Reference Model (DRM). FEA also enables an identification in redundancies, gaps, and cooperation possibility between institution.

2) Open Security Architecture (OSA)

OSA is a framework which was developed by security community and freely available online [7]. OSA offers a single consistent framework to simplify prerequisites from several widely available standards. OSA focuses on the relation between several related controls in security architecture. This is accomplished via identification towards generic patterns in designing security architecture to limit various security problems in IT infrastructures.

3) Sherwood Applied Business Security Architecture (SABSA)

SABSA is a framework and a methodology of security architecture and service management development in an enterprise, which is risk-driven [8]. SABSA aims to generate secure infrastructure solution. SABSA consists of five main layers, as seen in Figure 1.

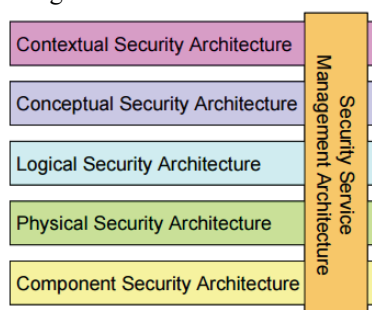


FIGURE 1. Security architecture in SABSA model.

The main character of SABSA model is the prerequisites that everything must be generated from business requirement

analysis in security aspects, especially if the security functions as a bridge that can help new business opportunities.

4) Control Objectives for Information and Related Technology (COBIT)

COBIT, which was developed by IT Governance Institute (ITGI), is a framework that provides services to an enterprise as a company, organization, or government, in governing or managing its assets or IT resources to move towards organization goals [9]. COBIT gives services of framework comprehensively to help government and IT management in a company to achieve initial goals. In COBIT, several processes as APO13 Manage Security, DSS04 Manage Continuity, and DSS05 Manage Security Services give a basic guideline in identifying, operating, and monitoring system for general security management.

5) ISO 27000 Family

ISO/IEC 27000-series, or commonly known as ISO27k, consists of information security standards that is published by ISO (International Organization for Standardization) and IEC (International Electrotechnical Commission) [10]. This standard incorporates wider aspects, which are not only limited in technical problems in IT. It is also usable by an organization in any size and form. ISO27k consists of many other standards, which is related each other, for instance, ISO 27001 that shows a list of security requirement and ISO 27003 that gives information regarding its corresponding implementation scheme.

6) The Information Technology of Infrastructure Library (ITIL)

ITIL, which is owned and developed by Office of Government Commerce of the United Kingdom (OGC-UK), is a series of concepts and techniques to manage IT infrastructure, including its development and operational. ITIL offers a best practice guideline for IT practitioners and business leaders to improve the quality and efficiency of the work so that reliable IT services can be achieved.

III. DEVELOPMENT METHODOLOGY

In this research, there are four main steps to develop the ESF, as depicted in FIGURE 2. The first step is to study the base theory, available security standards, and best practice of worldwide information security frameworks implementation. The result of this step is described in Chapter IV.

The second step is to perform analysis of existing security policy regarding the Information Security Management System (ISMS) in SKK Migas, which covers the organization's vision and mission, network architecture, and application architecture. To gather the existing condition information, we also performed interviews, focus group discussions (FGD), company visits, and comprehensive study of the security policy documents regarding ISMS in SKK Migas.

The next step is the synthesis of security framework which is based on the output of the previous two steps. Generally, the third step consists of framework synthesis based upon ISO 27000 standards, SABSA model, and the existing condition analysis in SKK Migas.

The last step is the continuation of the framework synthesis step. In this phase, an implementation roadmap is designed to

increase the quality of information security management system at SKK Migas. In this step, several programs that are recommended for SKK Migas to achieve quality increase is also created to keep the business running.

A. Integration of SABSA and ISO 27000 Model

The references of security framework in the development of ESF in SKK Migas are ISO 27000 and SABSA model. SABSA is an information security architecture development method, which is risk-driven. SABSA also provides solutions for security infrastructure that supports business initiation. SABSA is an open standard that covers models, methods, and processes that can be used freely by organizations who are willing to implement it.

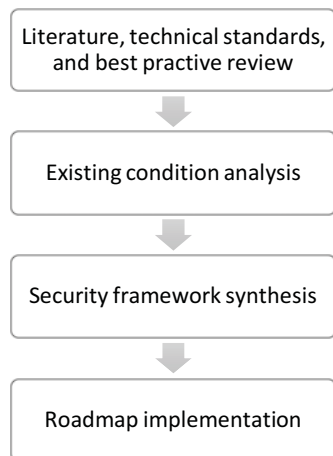


FIGURE 2. Four steps in framework development strategy.

The main difference between ISO 27000 and SABSA is its focus and granularity. ISO standards are security oriented and high-level standards, which makes it easier in the adoption at various level of organizations with diverse business processes. SABSA is more business process oriented and detail oriented to guide on what is compulsory to be carried out in each layer.

The integration of ISO 27000 standards and SABSA model generates a new framework which is more comprehensive in managing enterprise level information security. In this integration, each layer of SABSA will be validated with question lists regarding the asset management of the corresponding layer. The question list is a checklist and adjusted with corresponding clauses in ISO 27000. The detailed result of the integration is described in Section IV.

IV. ENTERPRISE SECURITY FRAMEWORK

In this chapter, we present the result of the framework development, which is specifically implemented for SKK Migas.

A. Analysis of Existing Security Policy

The analysis of existing security policy covers the network infrastructure and information systems in SKK Migas. The analysis of existing security policy also results in the documentation of information security governance and management in SKK Migas, which covers the various documents in Standard Operating Procedures (SOP). However, the main results of existing-condition analysis are the information security problems and threats.

The first problem is related to the data architecture. Currently, SKK Migas is not in possession of a data architecture that maps its entire managed and required data for its daily organization activity (ICT Blueprint). Besides the architecture, the data ownership problem is not yet clearly defined. Moreover, the format for data exchange in SKK Migas, e.g., PRODML, WITSML, XBRL, and FQR, are not yet formally standardized and associated with specific name.

In terms of communication network, the current communication scheme between head and branch office is utilizing a Virtual Private Network (VPN). However, it is still uncertain whether VPN is a secure and reliable solution.

Some problems may also emerge from the enterprise application, e.g., SAP. The enterprise application requires the network to open some particular port numbers to operate. The open port may also be a hole for any potential malicious threats or attacks. Moreover, there are no application development standards enforced in SKK Migas. There are also no standards in requirement and handling on security measure in the entire application. There is no system that stores and manages KKKS and external users, which provides authentication services for those users.

Lastly, data and information sharing with third-party actually needs a legal *umbrella*, which is currently unavailable. There is also no clear punishment for breaking the policy, standards, and SOP, for instance, in user and password management.

Initially, SKK Migas implemented ISO 27000 standards as its guideline for information security governance and management. The standard has been adjusted to match SKK Migas custom needs, as depicted in TABLE 1. The synthesis analysis is based on this information security domain/chapter.

TABLE 1. Information security domain/chapter in SKK Migas.

ESF Chapter	Information Security Domain
1.	Security Policy Management
2.	Organization of Information Security
3.	Human resource security
4.	Asset management
5.	Access control
6.	Cryptography
7.	Physical and environmental security
8.	Operations security
9.	Communications security
10.	System acquisition, development and maintenance
11.	Supplier relationships
12.	Information security incident management
13.	Information security aspects of business continuity management
14.	Compliance

B. Synthesis Analysis

In order to perform synthesis analysis on information security framework design in SKK Migas, we carried out an analysis of potential threats and their corresponding risks in the existing condition of IT infrastructure implementation in SKK Migas. The main components in risk identification are assets, threat sources, and vulnerabilities. The initial steps in governing risk management is knowing the potential risks of the corresponding organization.

In executing risk identification, we use a method that approaches on the assets, which means assets are the object of risk assessment. The risk assessment is performed according to the objective of the process, which is providing high-quality support and IT resources efficiently and effectively to increase the outcome of SKK Migas.

The analysis is based on the integration of two frameworks: SABSA and ISO 27000. We combine ISO 27000 with SABSA model to enrich the previously implemented ISO 27000 framework in SKK Migas. We go through each synthesis to describe the integration of ISO 27000 and SABSA to form the new framework. We refer each synthesis in ISO 27000 standards with the appropriate layer in SABSA.

TABLE 2. Integration of Security Policy Management.

1. Security Policy Management	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
5.1. Management direction for Information Security	L3-Logical

In ESF chapter 1, depicted in Table 2, security policy management means that it acts as a guideline and support for business process execution ins SKK Migas. It is implemented by paying attention to specific rules, international standards, and expert review about information security. As of the success measurement, document checklists are utilized.

TABLE 3. Integration of organization of Information Security.

2. Organization of Information Security	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
6.1 Internal Organization	L1-Contextual
	L2-Conceptual
6.2 Mobile devices and teleworking	L4-Physical

Organization of information security is a framework for implementation management of ISMS and a guideline of mobile devices and remote access in SKK Migas. As of the implementation strategy, SKK Migas is required to form a special task force for information security that is responsible to arrange SOP and corresponding standards of ISMS implementation in SKK Migas, which covers the accountability and best practice of management. It covers the contextual, conceptual, and physical layer of SABSA, as seen in Table 3.

TABLE 4. Organization of Information Security.

3. Human Resource Security	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
7.1 Prior to employment	L1-Contextual
	L5-Component
7.2 During employment	L2-Conceptual
	L3-Logical
7.3 Termination and change of employment	L5-Component

Depicted in Table 4, human resource security ensures SKK Migas' employees understand their responsibilities and ensures SKK Migas to protect the organization by protecting its employees. To implement this synthesis, SKK Migas is required to make sure that its employees are aware of their responsibility, for example, by signing a non-disclosure agreement (NDA). A successful implementation of this synthesis can be seen if there is an employee who performs law abuse or whether or not there is a proper counseling about employees right and responsibility.

TABLE 5. Integration of asset management synthesis.

4. Asset Management	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
8.1 Responsibility for assets	L1-Contextual
	L2-Conceptual
	L3-Logical
	L4-Physical
8.2 Information classification	L3-Logical
8.3 Media handling	L3-Logical
	L4-Physical

Asset management covers identification of organization's assets and proper protection to prevent abuse of asset information. To implement this, SKK Migas must renew its assets database periodically. As seen in Table 5, this synthesis covers almost all layers of SABSA, which means that asset management must encompass all hardware and software.

TABLE 6. Organization of Information Security.

5. Access Control	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
9.1 Business requirements of access control	L3-Logical
	L4-Physical
9.2 User access management	L2-Conceptual
	L3-Logical
	L4-Physical
	L5-Component
9.3 User responsibilities	L3-Logical
9.4 System and application access control	L2-Conceptual
	L3-Logical
	L4-Physical
	L5-Component

As portrayed in Table 6, access control synthesis is intended to limit certain access to particular information and devices. This can be performed by implementing several restrictions on the server, social media, databases, shared folder, and application. SKK Migas must also be aware of any external services or applications that have access to its IT infrastructure. The successfulness of this synthesis can be seen from the existence of certain supervision of its implementation.

TABLE 7. Integration of cryptography synthesis.

6. Cryptography	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
10.1 Cryptographic controls	L4-Physical
	L5-Component

Cryptography, depicted in Table 7, ensures proper and appropriate use of cryptography to protect confidentiality, validity, and integration of the information. This can be achieved by implementing appropriate cryptography algorithm to each communication channel and implementing Public Key Infrastructure of SKK Migas.

TABLE 8. Integration of physical and environmental security.

7. Physical and Environmental Security	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
11.1 Secure areas	L4-Physical
11.2 Equipment	L4-Physical

Physical and environmental security, depicted in Table 8, concerns about the physical layer that is aimed in the prevention of illegal access, abuse, and environmental threats about information and devices in SKK Migas from any unwanted party. Thus, any potential damage can be avoided. This can be

done by ensuring SKK Migas employs the state of the art of security practices.

TABLE 9. Integration of operations security synthesis.

8. Operations Security	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
12.1 Operational procedures and responsibilities	L3-Logical
12.2 Protection from malware	L4-Physical
12.3 Backup	L4-Physical
12.4 Logging and monitoring	L4-Physical
12.5 Control of operational software	L4-Physical
12.6 Technical vulnerability management	L4-Physical
12.7 Information systems audit considerations	L3-Logical
	L4-Physical

Operations security, which covers mostly physical layer of SABSA seen in Table 9, ensures proper and secure use of information processing devices so that any physical or non-physical threats can be avoided. To implement this, the IT managers must be aware of updating the devices to the latest version and regular checking must be performed as well.

TABLE 10. Integration of communications security synthesis.

9. Communications Security	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
13.1 Network security management	L3-Logical
	L4-Physical
13.2 Information transfer	L3-Logical
	L4-Physical

ESF chapter 8 ensures the security of each available communication line from any unauthorized access, both in physical and logical layer (see Table 10). SKK Migas must make sure that data and information exchange is performed via secure channels and the data must be approved by the managers prior to data exchange. The measurement of successfulness can be seen from the availability of the proper SOP and secure communication channels.

TABLE 11. Integration of System acquisition, development and maintenance.

10. System acquisition, development and maintenance	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
14.1 Security requirements of information systems	L3-Logical
	L4-Physical
14.2 Security in development and support processes	L1-Contextual
	L2-Conceptual
	L3-Logical
	L4-Physical
14.3 Test data	L4-Physical

In ESF chapter 9, depicted in Table 11, system acquisition, development, and maintenance defines that information security is an inseparable part of information lifecycle. To implement this, all IT devices security must be confirmed. Moreover, to ensure the right life cycle, system development and testing must be conducted in a separated environment. As of the measure of successfulness, SKK Migas can refer to application development that fulfills its development framework.

TABLE 12. Integration of supplier relationship synthesis.

11. Supplier relationships	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>

15.1 Information security in supplier relationships	L1-Conceptual
	L3-Logical
15.2 Supplier service delivery management	L1-Conceptual

Supplier relationship protects organizational assets from any unwanted access from third-party or suppliers. To implement this, performance monitoring of the third party suppliers must be in accordance with the supplier rules in SKK Migas. The successfulness of the implementation is indicated by the suitability of cooperation contract between SKK Migas and third party suppliers. As depicted in Table 12, this synthesis covers only conceptual and logical layers of SABSA.

TABLE 13. Integration of information security incident management.

12. Information security incident management	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
16.1 Management of information security incidents and improvements	L3-Logical
	L4-Physical

Information security incident management, which covers the logical and physical layer of SABSA seen in Table 13, defines the effective and consistent execution of information security incidence protection, which covers the event and weakness of the information security. The effective implementation strategy of this synthesis is related to comprehensive and efficient procedures of mitigation that mostly involves IT helpdesk.

TABLE 14. Integration of ESF chapter 12.

13. Information security aspects of business continuity management	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
17.1 Information security continuity	L2-Conceptual
	L3-Logical
17.2 Redundancies	L3-Logical

The ESF chapter 12, seen in Table 14, protects the continuity of information security so that it will always be within SKK Migas' Business Continuity Management System (BCMS). To achieve this goal, SKK Migas must perform proper data replication as a backup scheme and SKK Migas must stick to its Business Continuity Plan (BCP).

TABLE 15. Organization of Information Security.

14. Compliance	
<i>ISO 27000 Clause</i>	<i>SABSA Layer</i>
18.1 Compliance with legal and contractual requirements	L2-Conceptual
	L3-Logical
	L4-Physical

The last synthesis of the new framework, described in Table 15, tries to run prevention scheme of law abuse, rules, and contracts regarding information security. This synthesis cover SABSA conceptual, logical, and physical layer, which confronts any legal requirements in the system implementation.

C. Gap Analysis

Gap analysis of the information security is a method to compare the current ISMS with expected targets. Gap analysis also identifies corresponding actions or solutions to achieve expected targets. Gap analysis is performed based on 14 chapters in SKK Migas ESF. The results are summarized in Table 16.

TABLE 16. Gap Analysis in SKK Migas.

ESF	Gap Analysis	Solution
1	Not every component of policy management domain is implemented	SOP document review and constructing policy document for the undocumented business process
2	SOP for mobile devices and remote working is unavailable	Implementation of ISO 27000 and 20000 for mobile device and remote working
3	Appointed security standards are not fully executed	Security awareness training and ISMS internal counseling
4	Improved asset management system is necessary	Improving data architecture in terms of classification and treatment
5	Improved security technology in access control is needed	Implementing Public Key Infrastructure, Web Application Infrastructure, Data Loss Prevention, and Advance Persistent Threat
6	Weak access control that needs the corresponding policy to create more secure cryptography mechanism	Implementing Public Key Infrastructure and reviewing policies in cryptography use
7	Examination of availability and reliability of supporting facilities is needed	Examination of the availability and reliability of supporting assets, e.g., UPS, power generator, etc.
8	Network access control is not performed optimally	Review on network access control policies
9	Non-optimal segmentation in the computer network	Implementing proper network segmentation using VLAN and DMZ.
10	Lack of regular maintenance and assessment and also incomplete SOP documents	Performing regular maintenance and assessment, including regular training and updating DRP regularly
11	Incomplete policies, SOP, or standards that cover license and copyright matter	Arrangement and improvement of policies regarding copyrights and licenses
12	Non-optimal incidence management and incomplete SOPs	Application hardening based on state of the art of incident management standards
13	Non-optimal implementation of BCP and DRP	Updating DRP and BCP in a regular basis to enforce its implementation
14	Disobedience in policies, laws, and rules regarding information security	Improvement and enforcement on information security policies and awareness

D. Roadmap Analysis

Roadmap analysis is a continuation of Gap analysis, described in the previous section. It is also developed based on 14 chapters in SKK Migas ESF. The roadmap analysis focuses on specific milestones and deliverables to achieve expected

targets defined in gap analysis. It also defines the estimated time of completion to keep the project running on schedule.

V. CONCLUSION

The current study has presented the development of an Enterprise Security Framework which is based on SABSA and ISO 27000 model. The development consists of the following steps. The process was started by evaluating available information security standard and best practice used in enterprise scale. The next step is analyzing existing security policy and implementation regarding the Information Security Management System (ISMS) in SKK Migas and then perform gap analysis. The main step is the synthesis of security framework which intended to improve information security management in SKK Migas. The resulted security framework covers 14 security domains which will be used to control information security management within the institution.

ACKNOWLEDGMENT

The author would like to thank SKK Migas for the collaboration and funding this work.

REFERENCES

- [1] S. Migas, "Kegiatan Usaha Hulu Migas untuk Masa Depan yang Berkelanjutan, Sustainability Report SKK Migas 2013," 2013.
- [2] S. Migas, "Laporan Tahunan 2015," 2015.
- [3] J. Schekkerman, *How to Survive in the Jungle of Enterprise Architecture Frameworks: Creating Or Choosing an Enterprise Architecture Framework*. Trafford, 2004.
- [4] U. S. D. of Defense, "DoD Architecture Framework Version 2.02 - DoD Deputy Chief Information Officer," 2010. [Online]. Available: <http://dodcio.defense.gov/Library/DoD-Architecture-Framework/>.
- [5] W. Keller, *TOGAF 9.1 Quick Start Guide for IT Enterprise Architects*. Berlin, 2012.
- [6] and F. C. I. O. C. National Institute of Standards and Technology, Office of Management and Budget, *Federal Enterprise Architecture Security and Privacy Profile*. 2010.
- [7] OSA, "Open Security Architecture," 2016. [Online]. Available: <http://www.opensecurityarchitecture.org/cms/>. [Accessed: 08-Oct-2016].
- [8] S. Institute, "SABSA: Enterprise security Architecture," 2012. [Online]. Available: <http://www.sabsa.org/>. [Accessed: 09-Oct-2016].
- [9] J. W. Lainhart IV, "COBIT™: A methodology for managing and controlling information and information technology risks and vulnerabilities," *J. Inf. Syst.*, pp. 21–25, 2000.
- [10] I. O. for Standardization, "ISO/IEC 27001 - Information Security Management," 2013. [Online]. Available: <http://www.iso.org/iso/home/standards/management-standards/iso27001.htm>. [Accessed: 10-Oct-2016].